Write Up

Anggukan Sang Penjaga – Crypto

Flag :
CODEX26{4ngguk4n_p3nj4g4_m3mbuk4_p3t1}

Desc : Di bawah menara tua, Sang Penjaga tidak pernah membaca surat. Ia hanya meraba susunan batu di dalam amplop — tiap batu sama besar, dan wajah setiap batu terikat pada batu di belakangnya — lalu mengangguk jika semuanya terasa tepat, atau menggeleng jika ada yang janggal. Sebuah amplop curian telah jatuh ke tanganmu. Ia bersedia memeriksa amplop buatanmu berkali-kali, tetapi takkan pernah membacakan isinya.

Solution :

Amplop adalah AES-128-CBC dengan padding PKCS#7. Layanan hanya menjawab satu byte: 0x01 jika padding valid, 0x00 jika tidak. Kunci AES tidak perlu ditebak. Pada CBC, plaintext satu blok adalah dekripsi blok itu yang di-XOR dengan blok sebelumnya.

P_i = Dec_K(C_i) XOR prev
I = Dec_K(C_i) tetap selama C_i tidak diubah

prev adalah IV pada blok pertama, dan ciphertext blok sebelumnya pada blok berikutnya. Cukup kirim prev yang sudah diubah, disambung satu blok target. Protokol: kirim panjang uint16 big-endian, lalu blob. Ada empat blok ciphertext.

Yang diberikan :

- Hex dari IV (16 byte) disambung ciphertext (4 blok × 16 byte).
- Layanan jarak jauh yang hanya mengangguk atau menggeleng.

Langkah Untuk Mendapatkan Flag :

Persiapan

1. Baca hex amplop, buang baris kosong, ubah menjadi byte. Panjang harus kelipatan 16 dan minimal 32.
2. Ambil 16 byte pertama sebagai IV. Sisanya adalah ciphertext. Jumlah blok = panjang_ciphertext / 16.
3. Hubungkan ke layanan. Siapkan fungsi yang mengirim 2 byte panjang big-endian + blob, lalu membaca 1 byte balasan.

Pulihkan satu blok (ulangi untuk tiap blok)

Misal blok target C_i dan prev yang benar. Siapkan array intermediate I sepanjang 16 byte. Pulihkan dari byte paling kanan (indeks 15) ke kiri (indeks 0).

1. Untuk padlen dari 1 sampai 16: biarkan idx = 16 − padlen.
2. Salin prev menjadi crafted (bytearray).
3. Untuk setiap posisi j > idx yang sudah diketahui, set crafted[j] = I[j] XOR padlen. Ini memaksa plaintext hasil XOR menjadi nilai padding yang diinginkan.
4. Coba crafted[idx] dari 0 sampai 255. Untuk tiap tebakan, kirim crafted || C_i ke layanan.
5. Jika balasan 0x00, tebakan salah. Lanjut ke tebakan berikutnya.

6. Jika balasan 0x01 dan padlen = 1, lakukan uji false-positive: balik satu bit pada crafted[idx − 1], kirim lagi. Jika sekarang 0x00, anggukan pertama berasal dari padding asli yang lebih panjang — abaikan tebakan ini. Jika tetap 0x01, padding benar-benar 0x01.
7. Jika padlen > 1, anggukan langsung bisa dipercaya karena byte kanan sudah dikunci ke padlen.
8. Simpan I[idx] = tebakan XOR padlen.

Dari intermediate ke plaintext

1. Setelah 16 byte I terkumpul, hitung plaintext blok: P[j] = I[j] XOR prev_asli[j] untuk j = 0..15.
2. Simpan P. Untuk blok berikutnya, ganti prev menjadi C_i yang baru saja dipulihkan, lalu ulangi.

Gabungkan dan ambil flag

1. Gabungkan keempat blok plaintext berurutan.
2. Baca byte terakhir sebagai panjang padding PKCS#7. Pastikan n byte terakhir semuanya bernilai n, dengan $1 \leq n \leq 16$. Buang n byte itu.
3. Decode sisa byte sebagai UTF-8. Isi penuh dimulai dengan baris catatan:v1, lalu baris flag.
4. Ambil substring CODEX26{...}.

Catatan

1. Total pertanyaan sekitar sembilan ribu. Kunci AES tidak pernah ditebak.
2. Jangan mengirim seluruh amplop tiap kali. Cukup 32 byte: prev buatan + satu blok.